

🛡️ TFI — Seguridad en Sistemas de Información

Hackeo Remoto del Jeep Cherokee (2015)

Explotación remota de un vehículo sin modificaciones físicas

AUTOR

Bruno Lucarelli — Leg. 14988

DOCENTE

Ing. Ignacio Daniel Favro

INSTITUCIÓN

UTN — FR Villa María

TRABAJO FINAL INTEGRADOR • 2025

Un artículo de Wired cambió todo

Miller y Valasek tomaron control remoto del volante, frenos y motor de un Jeep en marcha — solo con su IP en la red celular de Sprint.

0

ACCESO FÍSICO REQUERIDO

6667

PUERTO TCP D-BUS

1.4M

VEHÍCULOS EN RECALL

4

LÍNEAS PYTHON → ROOT

Internet y CAN sin barrera

DOMINIO EXTERNO

 Sprint 4G

OMAP-DM3730

QNX + D-Bus

Uconnect

SIN GATEWAY

DOMINIO DE CONTROL

V850 (SPI)

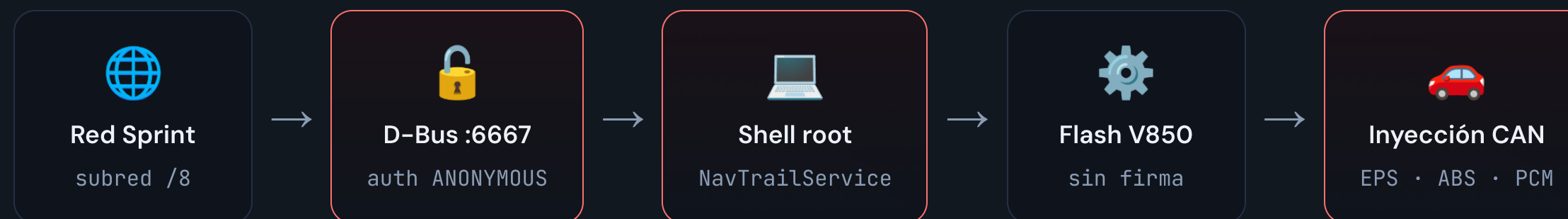
CAN-C

CAN-IHS

ABS · EPS · PCM

⚠ La radio estaba conectada simultáneamente a Internet y a los buses de seguridad activa del vehículo

De la IP al control físico



Vector remoto

Solo se necesitaba la IP del vehículo en la red celular



Sin modificación

Vehículo de fábrica, sin hardware adicional



Alcance nacional

Cualquier Jeep vulnerable en todo EE.UU.

Tres fallas de diseño



D-Bus expuesto

IPC local expuesto en TCP:6667 con autenticación ANONYMOUS. Método execute → shell root.



Sin segmentación

Head unit conectada directamente a CAN-C y CAN-IHS. Sin gateway ni filtrado entre dominios.



Firmware sin firma

V850 flasheable vía SPI sin verificación criptográfica ni Secure Boot.



GPS en tiempo real



Volante (EPS)



Frenos (ABS)



Apagar motor



HVAC / Audio



Escaneo masivo /8

De la venta al recall

- 2013 Jeep Cherokee sale al mercado con Uconnect integrado
- Oct 2014 Divulgación responsable a FCA: D-Bus expuesto
- Mar 2015 Se informa reprogramación del V850 y mensajes CAN arbitrarios
- May 2015 **Vector celular confirmado** — no solo Wi-Fi
- 21 Jul 2015 **Wired publica la demo** con Andy Greenberg al volante
- 24 Jul 2015 Sprint bloquea :6667 · FCA recall de **1,4 millones** de vehículos

¿Quién estuvo involucrado?



Investigadores (éticos)

Charlie Miller (Twitter) y Chris Valasek (IOActive). Financiados por DARPA.
Divulgación coordinada.



Víctima directa

FCA + ~1,4M propietarios de vehículos afectados en EE.UU.

TERCEROS CLAVE

Sprint — red celular

Harman — Uconnect

QNX — SO embebido

NHTSA — regulador

Congreso EE.UU. — Ley SPY Car



Hardware clave

OMAP-DM3730 · Renesas V850ES/FJ3 · Sierra Wireless AR5550
· CAN-C / CAN-IHS

Matriz ISO 31000 — Riesgo = $P \times I$

Escala 1–5 · Activos: frenos, dirección, motor, datos GPS del conductor

R1	25 — CRÍTICO	D-Bus sin auth en red celular
R2	20 — CRÍTICO	Sin aislamiento conectividad ↔ CAN
R3	20 — CRÍTICO	Flasheo V850 sin integridad
R4	20 — CRÍTICO	Escaneo masivo en subred /8
R5	16 — ALTO	Sin actualizaciones OTA automáticas

FCA vs. NIST SP 800-61

FASE	ACCIÓN	EVAL.
Preparación	Sin IRP ni CSIRT vehicular. Detección externa.	DEFICIENTE
Detección	Sin SIEM/IDS. 100% dependencia de investigadores.	AUSENTE
Contención	Sprint bloquea puerto 6667 (24 jul).	PARCIAL
Erradicación	Parche firmware 15.26.1 bloquea TCP entrante.	ACEPTABLE
Recuperación	Recall 1,4M — parche manual vía USB, sin OTA.	DEFICIENTE
Post-incidente	Sin lecciones aprendidas formales. Ley SPY Car propuesta.	MÍNIMO

Artefactos por volatilidad (RFC 3227)

ALTA

RAM OMAP · Caché ARP · Sesiones D-Bus activas en /dev/shmem

MEDIA

Logs QNX (slogger) · Filesystem ETFS/MMC · Registros celulares Sprint

BAJA

Imagen NAND flash · Dump firmware V850 · PCAP red · Bus logs OBD-II



Cadena de custodia

Jaula de Faraday · SHA-256 · Write-blocker
NAND



Contexto físico

El vehículo completo es el dispositivo de
evidencia



Marco legal

ISO/IEC 27037 · CPPN arts. 253-276
(Argentina)

Del parche reactivo al diseño seguro

1

Gateway CAN con whitelist

Dispositivo independiente del OMAP · AUTOSAR SecOC (MAC sobre CAN)

2

Hardening D-Bus

Sin exposición en red externa · TLS/mTLS · eliminar método execute

3

Secure Boot + firma V850

Challenge-response · HSM · ISO/SAE 21434

4

OTA seguras y automáticas

Verificación criptográfica · rollback · reporte de cobertura de flota

+

Secure SDLC + Programa CVD

Threat modeling · pentesting · canal formal de divulgación coordinada

La seguridad no es un accesorio

Las vulnerabilidades no fueron errores puntuales: fueron decisiones sistemáticas de diseño que ignoraron la segmentación, la autenticación y la integridad del firmware.

3

DOMINIOS A AISLAR

21434

ISO/SAE ESTÁNDAR

∞

COSTO DE NO DISEÑAR SEGURO

Bruno Lucarelli · brunolucarelli5@gmail.com · UTN FR Villa María